

Chapter 03

IAM

Identity and Access Management

IAM authenticates users

Protects account access

Prevents unauthorized use

Controls system access

Authentication Factors

Something you know

Something you have

Something you are

Something you do

Somewhere you are

Multi-Factor Authentication (MFA)

Uses multiple
authentication factors

Stronger than single factor

Reduces spoofing risk

Increases attacker difficulty

Two-Step Verification

Requires two
authentication steps

Often uses mobile device

- Text code entry

Additional verification layer

Passwordless Authentication

Does not use passwords

Uses alternative factors

Based on possession or biometrics

Reduces password risks

Single Sign-On (SSO)

One login for multiple systems

Reduces number of credentials

Simplifies authentication

Reduces password fatigue

Federated Identity Management

Third-party
authentication provider

Centralized
credential management

Used across organizations

Authentication
handled externally

Federated Identity Example

Users authenticate with
home system

Access external systems

Common in universities

Shared identity across domains

OpenID and SAML

OpenID supports federated login

Used by major platforms

SAML transmits
authentication data

XML-based assertion format

Privileged Access Management

Protects high-level accounts

Admin and root
accounts secured

Controls privileged access

Reduces misuse risk

Least Privilege and Just-in-time

Least privilege

- Only required access

Just-in-time access

- Temporary elevated access

Limits exposure duration

Credential Vaulting

Stores privileged
credentials securely

Centralized account vault

Users check out access

Time-limited credential usage

Secrets Management

Protects sensitive
authentication data

Includes keys and tokens

Secures admin credentials

Maintains confidentiality

Chapter 03

Data Protection

Synchronous vs. Asynchronous Encryption

Synchronous :

one key encrypts and decrypts

- Fast, but secure key delivery is the challenge

Asynchronous :

uses a public/private key pair

- Slower, but no key-sharing risk

How Asymmetric Encryption Works

Based on Diffie-Hellman and large prime numbers

- Private key stays with the recipient — always

Public key encrypts; only the private key decrypts

- Cracking it takes far longer than the exchange itself

Why We Use Both Together

Asymmetric sets up the connection and shares a key

- Solves the A-to-B key delivery problem

Then systems switch to symmetric for speed

- Enables secure communication between total strangers

Tokenization

Temporarily replaces sensitive values with placeholders

- Like arcade tokens hiding what's underneath

Reversible — original data can be retrieved when needed

- Used in password fields, payment forms, and call centers

Masking

Permanently replaces sensitive characters — irreversible

- Also called permanent tokenization

Keeps original format so the data type is recognizable

- Example: ****_****_****-1234 confirms identity without exposure